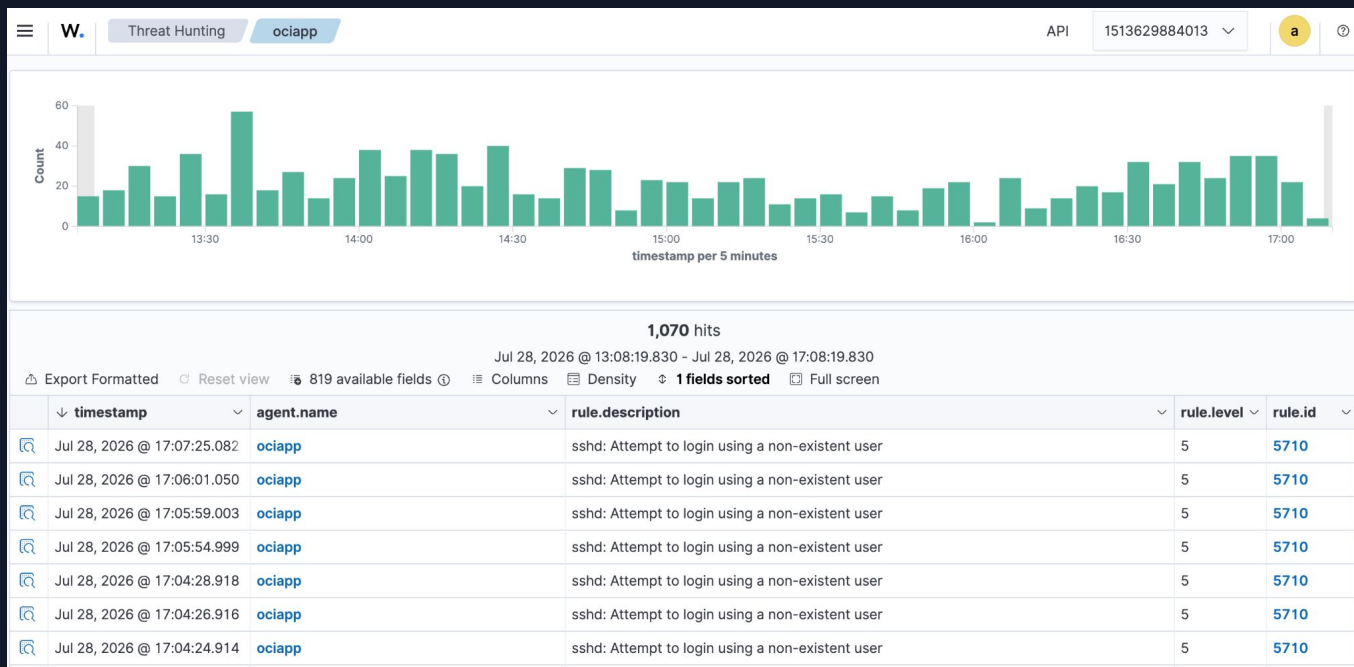


Process Mining na Cibersegurança

Ailton Cordeiro, 28 de julho de 2026

O PROBLEMA

Ataque persistente partindo de um IP



Document Details

[View surrounding documents](#)

[View single document](#)

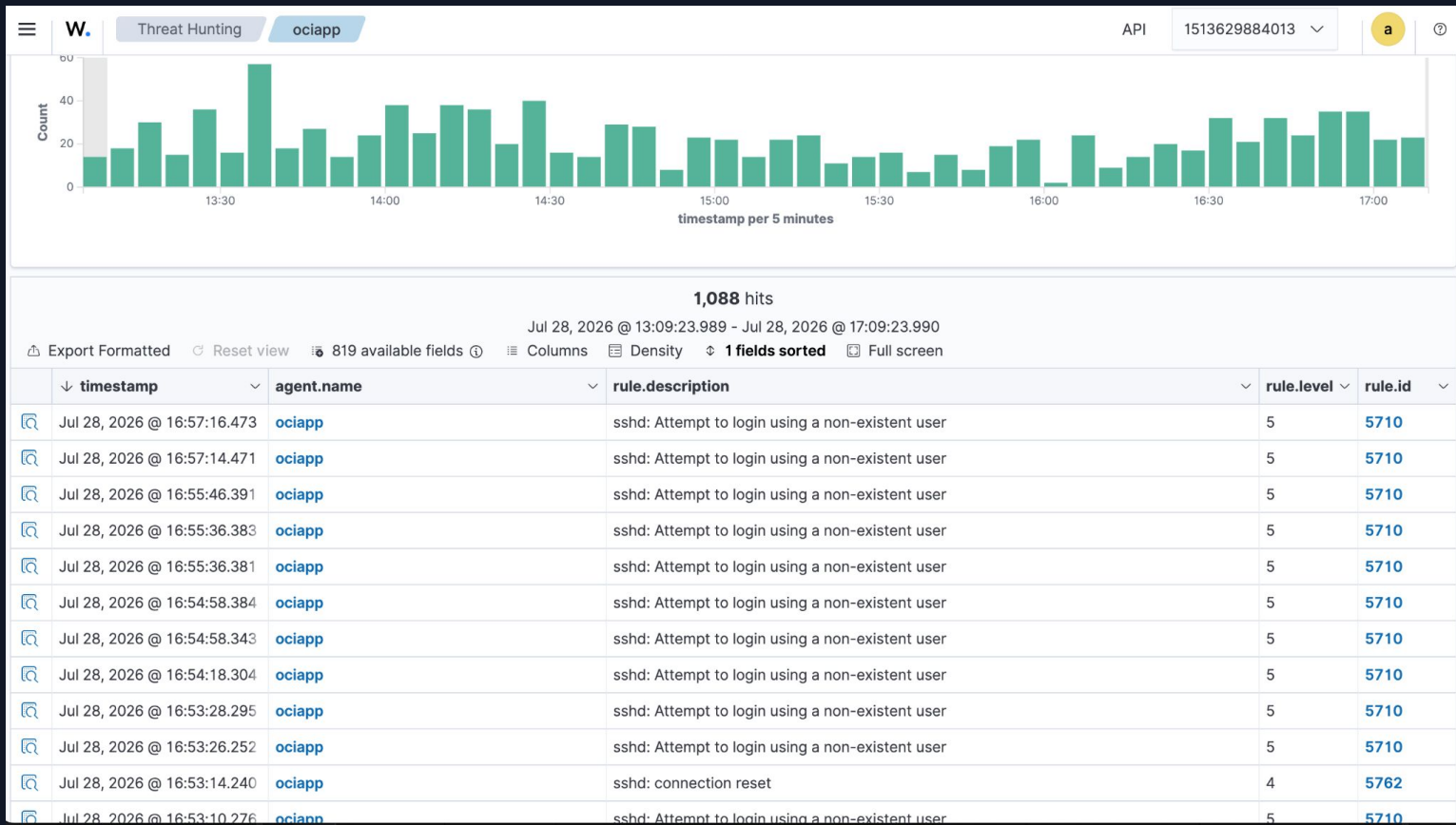
TableJSON

<code>GeoLocation.country_name</code>	Romania
<code>GeoLocation.location</code>	<pre>{ "lon": 25, "lat": 46 }</pre>
<code>_index</code>	wazuh-alerts-4.x-2026.07.28
<code>agent.id</code>	003
<code>agent.ip</code>	10.0.0.118
<code>agent.name</code>	ociapp
<code>data.srcip</code>	217.156.66.34
<code>data.srcport</code>	43666
<code>data.srcuser</code>	servers
<code>decoder.name</code>	sshd
<code>decoder.parent</code>	sshd
<code>full_log</code>	<pre>Jul 28 20:09:14 instance-20220216-0556 sshd[1865784]: Disconnected from invalid user servers 217.156.66.34 p ort 43666 [preauth]</pre>
<code>id</code>	1785269355.14699502
<code>input.type</code>	log

Bloqueamos o IP do atacante.



0 PROBLEMA



Por que ele voltou?



Document Details

[View surrounding documents](#)[View single document](#)

Table JSON

GeoLocation.city_name	San Jose
GeoLocation.country_name	United States
GeoLocation.location	{ "lon": -121.8914, "lat": 37.3388 }
GeoLocation.region_name	California
_index	wazuh-alerts-4.x-2026.07.28
agent.id	003
agent.ip	10.0.0.118
agent.name	ociapp
data.srcip	104.168.5.195
data.srcport	41516
data.srcuser	testuser
decoder.name	sshd
decoder.parent	sshd
full_log	Jul 28 20:08:43 instance-20220216-0556 sshd[1865665]: Invalid user testuser from 104.168.5.195 port 41516

Bloqueamos o IP do atacante na segunda.

Por que ele voltou na terça?

PARA A GESTÃO

Por que a defesa falhou?

PARA O TIME TÉCNICO

Indicador × comportamento.

A Pirâmide da Dor

Quanto mais alto o indicador, mais caro é para o adversário recomeçar.



A Pirâmide da Dor

Quanto mais alto o indicador, mais caro é para o adversário recomeçar.



IOC descartável

hash e IP mudam em minutos — sem custo para o atacante.

dor / custo
para o adversário



De indicadores para comportamento



Indicadores (IOC)

- **Hash, IP, domínio** — átomos do ataque
- **Trocados em minutos** — custo quase zero
- **Bloqueio reativo** — chega tarde
- **Alta rotatividade** — listas envelhecem sozinhas



Comportamento (TTP)

- **Como o adversário age** — o método, não o objeto
- **Persistente entre campanhas** — difícil de trocar
- **Deteção proativa** — caça por hipótese
- **Assinatura de conduta** — sobrevive à troca de IOC

Tática, técnica, procedimento

O PORQUÊ

Tática

O objetivo do adversário.

*ex.: movimento lateral, persistência,
exfiltração*

Tática, técnica, procedimento

O PORQUÊ

Tática

O objetivo do adversário.

*ex.: movimento lateral, persistência,
exfiltração*

O COMO

Técnica

O método de alto nível para
atingir a tática.

*ex.: execução remota via protocolo
administrativo legítimo*

Tática, técnica, procedimento

O PORQUÊ

Tática

O objetivo do adversário.

ex.: movimento lateral, persistência, exfiltração

O COMO

Técnica

O método de alto nível para atingir a tática.

ex.: execução remota via protocolo administrativo legítimo

O QUÊ, NA PRÁTICA

Procedimento

A implementação concreta — de um grupo ou ferramenta.

ex.: a sequência exata de comandos observada na campanha

MITRE ATT&CK

MITRE ATT&CK										
Matrices Tactics Techniques Defenses CTI Resources Benefactors Contribute Blog Search Q										
ATT&CK Matrix for Enterprise										
layout: side show sub-techniques hide sub-techniques										
Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Credential Access	Discovery	Lateral Movement
12 techniques	9 techniques	11 techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques	34 techniques	9 techniques
Active Scanning (3)	Acquire Access	Content Injection	BITS Jobs	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Access Token Manipulation (5)	Disable or Modify System Firewall (3)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Cloud Administration Command	BITS Jobs	Access Token Manipulation (5)	BITS Jobs	Disable or Modify Tools (6)	Brute Force (4)	Application Window Discovery	Internal Spearphishing
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Command and Scripting Interpreter (13)	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Build Image on Host	Domain or Tenant Policy Modification (2)	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Transfer
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Container Administration Command	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Debugger Evasion	Downgrade Attack	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	Deploy Container	Cloud Application Integration	Boot or Logon Initialization Scripts (5)	Deobfuscate/Decode Files or Information	Exploitation for Defense Impairment	Forge Web Credentials (2)	Cloud Service Dashboard	Remote Services
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	ESXi Administration Command	Compromise Host Software Binary	Create or Modify System Process (3)	Direct Volume Access	File and Directory Permissions Modification (2)	Input Capture (4)	Cloud Service Discovery	Replication Through Removable Media
Query Public AI Services	Generate Content (2)	Replication Through Removable Media	Exploitation for Client Execution	Create Account (3)	Domain or Tenant Policy Modification (2)	Execution Guardrails (2)	Modify Authentication Process (6)	Multi-Factor Authentication Interception	Cloud Storage Object Discovery	Software Deployment Tools
Search Closed Sources (2)	Obtain Capabilities (7)	Supply Chain Compromise (3)	Hijack Execution Flow (12)	Create or Modify System Process (5)	Escape to Host	Exploitation for Stealth	Modify Cloud Compute Infrastructure (5)	File and Directory	Container and Resource Discovery	Taint Static Content
Search Open Technical Databases (5)	Stage Capabilities (6)	Trusted Relationship	Input Injection	Event Triggered Execution (18)	Event Triggered Execution (18)	Hijack Execution Flow (12)	Masquerading (12)	Multi-Factor	Debugger Evasion	Use Alternate Authentication
Search Open Websites/Domains (3)	Valid Accounts (4)	Valid Accounts (4)	Inter-Process Communication (3)	Exclusive	Exclusive	Indicator Removal (8)			Device Driver Discovery	
Search Threat Vendor			Native API			Indirect Command Execution			Domain Trust Discovery	
									File and Directory	

<https://attack.mitre.org/>

MITRE ATT&CK

MITRE | ATT&CK

Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾ Benefactors Contribute Blog [Search Q](#)

ATT&CKcon 7.0 is coming October 27-28, 2026. [Learn more about ATT&CKcon 7.0.](#)

TECHNIQUES

Stealth ▾

Defense Impairment ▾

Credential Access ▾

Discovery ▾

Lateral Movement ▾

Collection ▾

Command and Control ▾

Exfiltration ▴

Automated Exfiltration ▾

Data Transfer Size Limits

Exfiltration Over Alternative Protocol ▾

Exfiltration Over C2 Channel

Exfiltration Over Other Network Medium ▾

Exfiltration Over Physical Medium ▴

Exfiltration over USB

Exfiltration Over Web Service ▾

Scheduled Transfer

Transfer Data to Cloud Account

Home > Techniques > Enterprise > Exfiltration Over Physical Medium > Exfiltration over USB

Exfiltration Over Physical Medium: Exfiltration over USB

Adversaries may attempt to exfiltrate data over a USB connected physical device. In certain circumstances, such as an air-gapped network compromise, exfiltration could occur via a USB device introduced by a user. The USB device could be used as the final exfiltration point or to hop between otherwise disconnected systems.

ID: T1052.001

Sub-technique of: T1052

① **Tactic:** Exfiltration

① **Platforms:** Linux, Windows, macOS

Contributors: William Cain

Version: 1.2

Created: 11 March 2020

Last Modified: 24 October 2025

[Version](#) [Permalink](#)

Procedure Examples

ID	Name	Description
S0092	Agent.btz	Agent.btz creates a file named thumb.dd on all USB flash drives connected to the victim. This file contains information about the infected system and activity logs. ^[1]
S0409	Machete	Machete has a feature to copy files from every drive onto a removable drive in a hidden folder. ^{[2][3]}
G0129	Mustang Panda	Mustang Panda has used a customized PlugX variant which could exfiltrate documents from air-gapped networks. ^[4]

<https://attack.mitre.org/T1052/001/>

MITRE ATT&CK

TTPs · 07 16

Três lentes, não concorrentes



Cyber Kill Chain

a sequência temporal do ataque

- 1 Recon
- 2 Armar
- 3 Entregar
- 4 Explorar
- 5 Instalar
- 6 C2
- 7 Ação



Diamond Model

o eixo de atribuição



Vocês já têm a ferramenta

LOG (CSV)

eventos crus:
case · atividade · hora



gerar_dfg.py

descobre o
Directly-Follows Graph



DFG + ALERTAS

mapa de comportamento
+ desvios

Hoje vamos investigar uma ameaça interna.

Descoberta: o que o log revela

OBJETIVO Descobrir o DFG do log novo e ler o fluxo normal.

```
$ python3 gerar_dfg.py --dataset dia2_ameaca_interna.csv
```

RESPONDA / FAÇA

- Qual é o caminho mais frequente (o "caminho feliz")?
- Quais atividades novas aparecem, que não existiam no fluxo do dia 1?
- Alguma delas são fora do esperado? Por quê?

CHECKPOINT o .png do DFG aberto e a lista de atividades novas anotada.

O grafo é um mapa de comportamento

ATIVIDADE NO LOG	TÁTICA ATT&CK	TÉCNICA
Busca_Arquivos	Discovery	T1083 — File & Directory Discovery
Acesso_Arquivo_Sensível (repetido)	Collection	T1005 — Data from Local System
Compactar_Arquivos	Collection	T1560 — Archive Collected Data
Upload_Externo	Exfiltration	T1567 — Over Web Service
Copia_Dispositivo_USB	Exfiltration	T1052 — Over Physical Medium

Aquele ramo estranho é uma cadeia ATT&CK inteira: **Discovery → Collection → Exfiltration.**

A caça: quem é o insider?

OBJETIVO Caçar o insider pelo comportamento — e ver a regra herdada falhar.

```
$ python3 gerar_dfg.py --dataset dia2_ameaca_interna.csv --usuario usuario_08
```

RESPONDA / FAÇA

- Olhe os alertas: quantos casos a regra sinalizou? É o comportamento perigoso do grafo?
- Gere o DFG individual dos suspeitos e compare com o agregado.
- Quem é o insider? O que a regra deixou passar — e por quê?

CHECKPOINT nomear o insider e explicar por que a regra herdada falhou.

INTERVALO

15 minutos

Detecção comportamental e purple team

Vocês acharam o insider com o olho. O trabalho agora é transformar essa hipótese comportamental numa regra que dispare sozinha.

FALSO NEGATIVO

deixar o insider passar — como a regra do dia 1 fez.

FALSO POSITIVO

acusar quem só acessou um arquivo normal antes do sensível.

O LOOP DE PURPLE TEAM

RED emula a TTP

→ **BLUE** constrói a detecção

→ **RED** tenta evadir de novo

Engenharia de detecção

OBJETIVO Escrever uma regra comportamental que pega o insider sem falso positivo.

```
$ # estenda gerar_dfg.py: uma função que olha a SEQUÊNCIA de cada caso
```

RESPONDA / FAÇA

- Dispare nos três casos do insider (O19, O20, O21).
- NÃO dispare nos casos benignos (O13, O14) — a armadilha de falso positivo.
- Bônus (purple): ranqueie todos os casos por risco. Quantos falsos positivos sobraram?

CHECKPOINT a saída da caça com o insider no topo do ranking.

TTP como processo

O que vocês fizeram num CSV de 21 casos é, em escala controlada de uma detecção de ameaça.

HOJE

21 casos, 1 CSV



EM ESCALA

milhares de eventos reais de endpoint — detecção de APT por mineração de processos

- **O DFG é o degrau de entrada** — algoritmos mais expressivos (ex.: Inductive Miner) lidam com ruído e concorrência.
- **A caça de desvios tem nome** — conformance checking: comparar o observado a um modelo do esperado.
- **O gargalo real é o dado** — transformar log cru e barulhento em log de eventos limpo é 80% do trabalho.

Três lições

01

A regra de ontem é cega para o ataque de hoje

a detecção herdada gritou pelo inocente e ignorou o insider.

02

O comportamento estava nos dados o tempo todo

bastou olhar o processo, não o evento isolado.

03

Detecção comportamental é combinar sinais fracos

e calibrar o limiar entre pegar tudo e afogar em falso positivo.

Obrigado.

Perguntas?